

Wherever I May Roam: Stealthy Interception and Injection Attacks through Roaming Agreements

Swantje Lange^{1,3}, Francesco Gringoli², Matthias Hollick¹, and Jiska Classen³

¹ Secure Mobile Networking Lab (SEEMOO),
Department of Computer Science, TU Darmstadt, Germany
`{slange,mhollick}@seemoo.de`

² University of Brescia/CNIT, Brescia, Italy
`francesco.gringoli@unibs.it`

³ Cybersecurity – Mobile & Wireless,
Hasso Plattner Institute, University of Potsdam, Germany
`jiska.classen@hpi.de`

Abstract. Cellular network users can be attacked through Rogue Base Stations (RBSes). 3G introduced network authentication as a mitigation. However, roaming partnerships between network operators allow requesting authentication vectors. This feature opens doors for state-sponsored attackers with access to roaming infrastructure, allowing the operation of stealthy RBSes anywhere in the world. This by far exceeds what lawful interception interfaces were designed for but provides attackers with similar capabilities, such as network traffic interception, manipulation, and injecting management frames towards a user’s device. Updated 5G roaming procedures do not prevent this issue. We demonstrate that modern smartphones effectively cannot indicate such attacks to end-users.

Keywords: 5G · Roaming · MitM Attacks · Baseband Exploitation

1 Introduction

High-value targets of state-sponsored attackers, like politicians, activists or journalists, have difficulty protecting themselves from attacks on their mobile devices. In 2G, attackers can set up a RBS and mimic a real network. Due to the lack of mutual authentication [45] they can force nearby devices to connect. This risk is well-known to mobile device vendors, who integrated the possibility to turn off 2G on iOS and Android [15,46], thus prioritizing security over connectivity. The mutual authentication introduced in 3G shrinks the overall attack surface to a minimal set of pre-authenticated protocol messages [44].

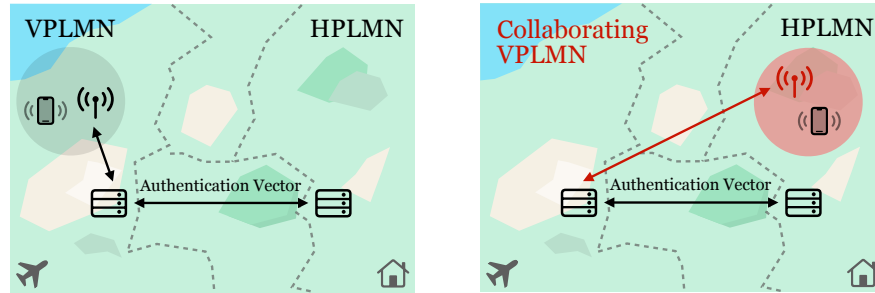
Abusing roaming mechanisms, a state-sponsored attacker collaborating with a Mobile Network Operator (MNO) can reach a mutually authenticated Machine-in-the-Middle (MitM) position. In a legitimate roaming case, the user’s Home Public Land Mobile Network (HPLMN) provides the Visited Public Land Mobile Network (VPLMN) with the Authentication Vector (AV) required for mutual authentication (see Figure 1). Due to the lawful interception regulations, an MNO

can always observe the traffic of its users within its own country. However, if an MNO intercepts traffic outside its country, it breaks the regulations [12, 4.4.6]. In this paper, we show that even in 5G, countries can spy on each other—there are no technical countermeasures that prevent traffic interception in fake roaming scenarios. In an attack scenario, the attacker acts as a VPLMN without the user being in the physical area of that VPLMN. The attacker may use the authenticated connection for network monitoring or as an entry point for Remote Code Execution (RCE).

The target can hardly notice the attack as the User Equipment (UE) does not provide a possibility to display or review the trust assumptions behind the current connection. For the target’s HPLMN, it is difficult to decide if a request for an AV is legitimate, as their primary interest is to ensure billing. Rejecting AV requests might cause a loss in revenue. In contrast, the attacker does not aim to bill the target’s HPLMN for the established connection. Additionally, the connection established by the attacker might be concise and without data transfer. Our analysis confirms the practicability of attacks on roaming. The issues we found in the 5G specifications and implementations are the following:

- The specifications are only optimized to prevent billing fraud when roaming.
- Trust assumptions and decisions about authentication in roaming are made in the core network, the UE is not involved (except for turning off roaming).
- Roaming partners can arbitrarily choose the current network name displayed on a UE as it is not part of the authentication.

We practically demonstrate these weaknesses in the specifications in a lab setup with recent Android devices and iPhones and the Open5GS project [35]. Further, we passively confirm the issues in real-world cellular networks. We contacted the 3rd Generation Partnership Project (3GPP), GSM Association (GSMA), MNOs, and mobile operating system manufacturers to raise awareness about this issue. Effective solutions will require all of these parties to collaborate to redesign lawful interception interfaces such that they only allow legitimate use cases and display indicators of abuse in roaming structures on end devices.



(a) Legitimate roaming architecture; logical and physical location are the same. (b) Abuse of roaming mechanisms; logical and physical location do not match.

Fig. 1: Targeted users can be attacked outside of the roaming agreement.

2 Background

Roaming allows a UE to authenticate with networks while traveling abroad. More specifically, a user subscribed to their HPLMN is temporarily located in a VPLMN. This section describes the details required to understand interception attacks on roaming.

2.1 Lawful Interception Interfaces and Regulations

Lawful Interception (LI) is used by MNOs to provide Law Enforcement Agencies (LEAs) with communication data of a specific user, i.e., the target. An LEA provides an MNO with a warrant to intercept the target's communication [11, 3.1]. The MNO needs to capture the contents and metadata of the target's communication, enabling the LEA to get the context of the communication [11, 6.3]. The interception shall take place undetectable by any other party and shall comply with the legislation in place [11, 6.1, 6.5, 6.6].

Usually, cellular network traffic is only encrypted on the over-the-air interface between UE and Next generation Node B (gNB) [6, 5.2.2, 5.3.2]. This way, third parties cannot overhear the communication. However, the gNB and the network functions of HPLMN and VPLMN can intercept the traffic decrypted at the gNB, as confidentiality protection is optional [1, 5.1]. For Voice over LTE (VoLTE) and Voice over New Radio (VoNR) calls, merely integrity protection is added [20, E.1.2]. Thus, the content of calls can still be observed.

In the case of roaming, MNOs are only allowed to intercept traffic within their own network [12, 4.4.6]. They may intercept traffic of inbound roaming targets but only tap traffic of outbound roaming targets if it is home-routed [9, 7.4.7.4][10, 8.2.2.3ff]. When a target joins or leaves the network, the MNO informs the LEA. Based on the roaming agreements in place, a target's HPLMN provides the VPLMN with long-term identifiers, facilitating the interception [11, 6.3].

2.2 Roaming in 5G

Security between PLMNs We assume that connections between the VPLMN and HPLMN are secure. Security Edge Protection Proxy (SEPP) protects control plane messages [6, 4.2.1], while Inter-PLMN User Plane Security (IPUPS) protects user plane messages [6, 4.2.2].

(Ab)Using Roaming Users aim to have network connectivity while traveling, even if their MNO is not present in a country. Therefore, MNOs make roaming agreements, enabling billing both customers and roaming partners.

For compatibility reasons, authentication between a UE and a base station follows the same steps with and without roaming. Only the core networks handle authentication requests and route network traffic. In either case, the wireless connection is secured based on the secrets of the user's Universal Subscriber Identity Module (USIM) [6, 6.2.2.2].

We assume that the VPLMN provides access to a state-sponsored attacker while the user's HPLMN, a trusted entity, is not compromised. The HPLMN could access a user's network traffic in any case through LI. The attacker operates a 5G base station, also named gNB, and has a connection to the VPLMN.

Authentication in a Roaming Scenario The basic goal of authentication is to authenticate the user to the network and vice versa. In 5G, the authentication follows the 5G Authentication and Key Agreement (AKA) protocol [6, 6.1.3.2]. A detailed description of 5G AKA can be found in the Appendix. Figure 2 illustrates the authentication flow. In a roaming scenario, the VPLMN relays the authentication to the HPLMN. To prevent billing fraud, the VPLMN needs to provide the HPLMN with a proof of presence verifying that the UE is connected to the network of the VPLMN [6, 6.1.4]. Thereby, users will only be billed if they actually used the network of the roaming partner.

5G AKA is only designed to inhibit billing fraud. Thus, it does not protect from a VPLMN, which only seeks to access a user's data without aiming for billing fraud. By means of LI, a VPLMN with an active connection to a user is authorized to intercept the user's traffic. As 5G AKA merely verifies the numer-

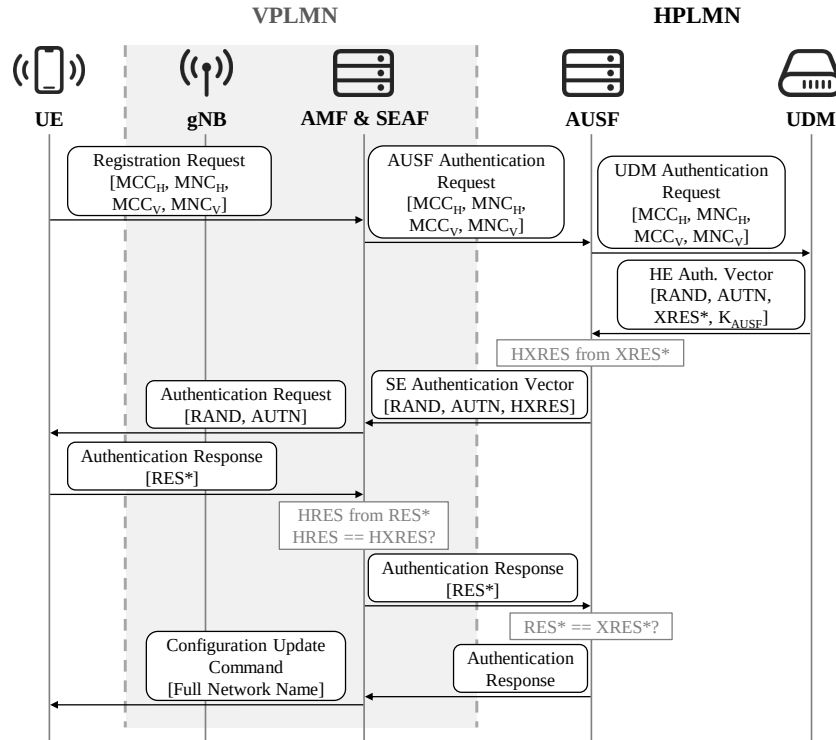


Fig. 2: Messages exchanged for authentication in a 5G roaming scenario.

ical Mobile Country Code (MCC) and Mobile Network Code (MNC) but not the network name displayed on the phone, a VPLMN can establish a connection to a UE unnoticeably by announcing the network name of the user’s HPLMN. An analogy in computer networks would be to only check for the numeric IP address, similar to the MCC and MNC, when all the end-user sees is the domain name provided over DNS.

In a roaming scenario, the network name displayed on a mobile phone is not authenticated by the trusted HPLMN.

3 Attacker Model

We consider a state-sponsored attacker who collaborates with an MNO, which can be coerced into following their orders. E.g., MNOs can be forced to provide access through LI. To set up the RBS, the attackers utilize pre-configured Software-Defined Radios (SDRs) attached to the MNO’s network. As network traffic can be routed globally, the attacker can be located in the same or a different country as the collaborating MNO. Additionally, the attacker may possess cellular baseband RCE exploits. A similar combination of operator-level network access and possession of zero-day exploits has been uncovered in recent attacks, where exploits were injected through the core network [38,50] or RBSes [13,14].

The attacker aims to use RBSes for MitM attacks and as a possible entry point for RCE. The RBS position is closer to the target, meaning it does not require collaboration with a core network for exploit injection. At the same time, wireless protocols are exposed, enabling baseband exploitation in addition to browser exploitation. In 2G, RBS setup is trivial, as only the UE authenticates towards the network behind the base station but not vice versa [44]. High-value targets are aware of such attacks and follow security best practices. On iOS, 2G can be turned off in Lockdown Mode [15]. Android also supports turning off 2G and enforcing strong encryption [29,46]. Thus, the attacker considered in this paper must bypass the mutual authentication introduced in 3G.

The pre-authentication attack surface of cellular baseband chips in UEs is limited to a small subset of protocol messages. A UE only sends further data to a base station after successful network authentication, including management and network traffic. Communication between the UE and base station is only encrypted over-the-air and decrypted on the base station. Thus, an RBS can act as MitM [14]. However, overhearing network traffic as MitM is highly limited through Transport Layer Security (TLS). As state-sponsored attackers want to know as much as possible about their target, they may acquire zero-day exploits. Compared to exploits targeting browsers and mobile operating systems, cellular baseband exploits have high reliability as baseband firmware lacks basic protection mechanisms, including secure heap implementations or stack canaries [37,48,51,23,24]. Baseband co-processor inputs to the main processor on a smartphone are often insufficiently sanitized, allowing it to pivot

into the operating system [21,34,40]. The code reachable post-authentication increases [51], leading to a higher probability that bugs resulting in RCE exist. We assume that post-authentication RCE exploits generally have higher availability and lower prices. Pricing by exploit brokers indicates that baseband exploits are comparably cheap [42,54], motivating attackers to set up RBSes. RBS-based attacks leave little traces outside the attacker-controlled environment, supporting stealthy operations. A recent report on spyware vendors shows that usage of higher-priced browser exploits can be detected and patched within a few days [32], while baseband exploitation has not yet been uncovered in public, and critical vulnerabilities reported take multiple months to patch [51].

4 Attacks on 5G Roaming

A state-sponsored actor aims to remain undetected while abusing roaming for MitM and RCE attacks. To this end, the attacker can abuse that the only mutually authenticated network information in 5G AKA is the Public Land Mobile Network (PLMN) ID, represented by its unique MCC and MNC. This opens various attack vectors, which we describe and evaluate in the following.

4.1 Exploiting the System

Using the peculiarities described above, a state-sponsored attacker could trick a targeted user into connecting to their gNB. The MNO has a roaming agreement with the HPLMN of the targeted user. One scenario in which the attack could be conducted is that the attacker travels with their collaborating gNB where the target currently stays. Due to physical proximity, the target's UE connects to the collaborating gNB. The collaborating gNB relays the UE's Registration Request via the Internet to the core network of the MNO it collaborates with. The collaborating MNO serves as VPLMN. Following the roaming agreement, the VPLMN requests an authentication vector at the target's HPLMN, as described in the appendix. This way, the connection between the target's UE and the VPLMN is mutually authenticated.

Once authenticated, the attacker can intercept network traffic. An attacker can further leverage the gNB's capability to inject low-layer management frames towards the UE. This could be used as an entry point for RCE, which gives full control over the phone to an attacker. A connection for a couple of seconds to run an exploit suffices.

To prevent the target from noticing the connection to a network different than their HPLMN, the attacker can deliberately choose the network name displayed on the target's UE. If the target disabled roaming on their UE, the attacker can trick the UE into a connection by setting the MCC and MNC announced by their gNB to the MCC and MNC of the target's HPLMN.

Usually, a VPLMN has a high interest to employ Home-Routed (HR) as this allows them to bill the HPLMN for the network traffic induced by their customer. In case of a targeted attack, the interest in handling the user's traffic by itself might be higher so the VPLMN may choose to use Local Breakout (LBO).

4.2 Network Name Displayed on UE

Users only have a few possibilities to observe roaming on their UE. On iOS, the only one is the network name displayed on their home screen. Android additionally displays an “R” in the reception bar status if MCC and MNC of the network do not match the ones in the USIM. Figure 3 compares both user interfaces. Tampering with the network display name is essential for attackers to stay stealthy on both operating systems. Manipulation of MCC and MNC further hides the roaming indicator “R” on Android.

Display Name Priorities in the 3GPP Specification The network name shown to the user may originate from either the USIM, the Network Identity and TimeZone (NITZ) information received from the network, or the Mobile Entity (ME). According to [7, A.3], the USIM has the highest priority in providing a network name. The USIM stores multiple files mapping display names to PLMNs. The PLMN Network Name (PNN) file stores the full and short names of networks the UE connected to [3, 4.2.58]. In the Operator PLMN List (OPL) file, the USIM maps multiple PLMNs to PNN entries [3, 4.2.59]. If the OPL file is empty and the UE is in the HPLMN, the first entry of the PNN file is used as default network name. The Service Provider Name (SPN) file only stores the HPLMN name for the specific purpose of displaying it on the UE [3, 4.2.12].

The display name stored in the ME has the lowest priority [7, A.3]. It will be overwritten when the PLMN sends an NITZ message containing a display name. NITZ enables an operator to update its identity and to communicate this with the UE [2, 4]. The display name updated via NITZ is stored by the ME, so it will not be deleted when the UE reboots or the USIM is removed [2, 6.2].

Display Name Priorities on iOS There is no public information about the display name selection procedure on iOS. According to the documentation for



(a) iOS prioritizes the display name provided by NITZ, without further roaming indicators. (b) Samsung devices on Android 13 show the NITZ name along with the HPLMN’s name read from the USIM, and the roaming “R” on the reception bars.

Fig. 3: Status bar displaying network name and properties during roaming.

Table 1: Display names resulting from different name sources in iOS 17.3.

Operator	USIM SPN	USIM OPL	USIM PNN	BB $\rightarrow$ iOS	BB Type	TS25 List on iOS	Name Displayed
Non-Roaming							
Telekom.de	Telekom.de	Telekom.de ①	Telekom.de ①	Telekom.de	OPL	Telekom Germany GER	Telekom.de
Aldi Talk	MEDIONmobile	MEDIONmobile ①	MEDIONmobile ①	MEDIONmobile	OPL	o2 - de	MEDIONmobile
Germany ④ Poland							
Telekom.de ④ T-Mobile.pl	Telekom.de	—	—	T-Mobile #5GBardziej Plus	NITZ	T-Mobile.pl	T-Mobile #5GBardziej Plus
Telekom.de ④ Plus	Telekom.de	—	—	Orange	NITZ	Plus	Orange
Telekom.de ④ Orange	Telekom.de	—	—	—	NITZ	Orange PL	Orange
Germany ④ France							
Telekom.de ④ Orange F	Telekom.de	—	—	Orange F	NITZ	Orange F	Orange F
Telekom.de ④ F-Bouygues	Telekom.de	—	—	F-Bouygues Telecom	TS25	F-Bouygues Telecom	Bouygues*
Telekom.de ④ F SFR	Telekom.de	—	—	SFR	TS25	F SFR	SFR*
Germany ④ United Kingdom							
Telekom.de ④ EE	Telekom.de	—	—	EE	NITZ	EE	EE
Telekom.de ④ O2 - UK	Telekom.de	—	—	O2-UK	TS25	O2 - UK	O2-UK
Telekom.de ④ Vodafone UK	Telekom.de	—	—	Vodafone UK	TS25	Vodafone UK	Vodafone UK
Germany ④ United States							
Telekom.de ④ T-Mobile	Telekom.de	—	—	T-Mobile	TS25	T-Mobile	T-Mobile
Telekom.de ④ AT&T	Telekom.de	—	—	AT&T	NITZ	AT&T	AT&T
Telekom.de ④ 313 100	Telekom.de	—	—	313 100	—	—	SOS only
Simulation							
Frida Script	Not Requested	① "OPL"	"PNN"	"Long", "Short"	OPL, TS25, NITZ	Unchanged	"Long" Name (OPL, NITZ)

④ Operator A roams to operator B.

① Operator entry mapped to the following operator name(s).

① Only operator with an entry in OPL or PNN list.

* iOS carrier bundle specifies different name that overwrites baseband's TS25 information.

BB $\rightarrow$ iOS is the name that is indicated by the baseband chip to be displayed to the user, along with a flag indicating the baseband's name source.

non-public LTE and 5G networks used with iOS 17 [16], the network name can be set using the NITZ, OPL, PNN, and SPN, but it is unclear which priority is given to these name sources. Thus, we reverse engineer, passively observe, and simulate the display name priorities. We test which name is shown by connecting to real-world networks in Germany, Poland, France, the United Kingdom and the United States, and further simulation using Frida scripts (see Table 1).

One possible name source is information stored on the UE. We analyze iOS 17.3 for an iPhone 14 Pro [17]. By searching for network name strings, we identify the following sources with hardcoded network names: Carrier bundles for each operator known to Apple⁴, a default carrier bundle with network names specified in TS25 [30]⁵, and the Qualcomm cellular baseband firmware⁶.

Another source storing display names is the USIM. We analyze the data exchanged between USIM and the Qualcomm baseband using SIMtrace2 [43], as shown in Figure 4a. Network names in the USIM are UTF-8 or GSM7-encoded. A search for these name representations reveals the following order in which files are read from the USIM: (1) SPN, (2) all OPL entries, and (3) all PNN entries. On the USIMs in our experiments, these entries are never updated by the network operator, even in the case of roaming.

The baseband and iOS exchange information using Qualcomm MSM Interface (QMI). By observing this information with a baseband debug profile [18,19], we can search for QMI messages that contain the network name as a string. QMI UIM messages originate from the USIM, whereas QMI Non-Access Stratum (NAS) messages represent information derived from network activity. The baseband sends the following messages to iOS when a USIM is inserted:

1. UIM file read for all OPL entries,
2. UIM file read for all PNN entries,
3. NAS operator name, and
4. NAS current PLMN name with source (OPL, TS25, NITZ).

Even if the USIM stores an SPN entry, iOS does not attempt to read it. We assume that the baseband firmware requests and handles the SPN internally. The final NAS message contains the PLMN name in short and long form. The baseband indicates the MCC, MNC, and name source in this message.

In our experiments, iOS only displays the long form of the network name provided in the NAS PLMN name message. Names in other messages are ignored. Contrary to the message type NAS, which indicates information originates from the network, the name sources used NAS PLMN name messages are OPL, TS25, or NITZ. Without roaming, all our USIMs have SPN and OPL entries. Here, the name source is set to OPL. In roaming, the initial name comes from the TS25 list, but is updated to the NITZ name within a few milliseconds if NITZ is active. Without NITZ, the network name is looked up in the network operator’s carrier bundle, which can overwrite the display name if the

⁴ Located at `/System/Library/CarrierBundles/`.

⁵ Located at `/System/Library/CarrierBundles/iPhone/Default.bundle/TS25.txt`.

⁶ ZIP-compressed file at `/Firmware/Mav22-2.20.06.Release.bbfw`.

property `StatusBarCarrierName` is set. Some carrier bundles, such as the one for non-public networks [16], do not have this property set. We conclude that the priorities observed in real-world networks during roaming are as follows: NITZ information gets the highest priority if used, followed by the carrier bundle status bar name if set, and if both fail, TS25 names are used as a fallback.

However, network operators might run different setups or change their configuration. Thus, we simulate the priorities of the names provided by the baseband and network with the following experiment. Using Frida scripts for baseband experimentation [34,47], we modify the QMI packets before iOS parses them. With this setup, we can replace network names in UIM and NAS messages. We leave all remaining messages intact. Using this setup, we can test any USIM, including commercial providers where we cannot access the USIM’s key material. iOS always shows the last network name provided by the NAS PLMN name message. For the name sources OPL and NITZ, it takes the long name, while it looks up the name in the TS25 list if the name source is set to TS25.

During roaming, iOS gives priority to the display name provided by NITZ. The user interface lacks additional indicators for roaming.

iOS displays further variants of the operator name in other user interface elements. The heading in the cellular SIM settings is provided by the iOS carrier profile, i.e., *Non-Public Network* when using one of the non-public test PLMNs [16]. The names in the manual network selection menu are provided by the baseband chip, which reports a list of network names. In this list, the names follow the ones specified by TS25, but are generated by the baseband. The baseband chip overrides the TS25 name if the USIM stores a different network name. These examples show further display name inconsistencies, however, these are less present to the user.

Our experiments confirm that the display name can be configured in various ways. Which properties are used differs across network operators. This is especially dangerous on iOS, as roaming only becomes visible through the network name—a property that can be easily overridden by a malicious VPLMN.

Display Name Priorities on Android On Android, manufacturers use different basebands, making it difficult to observe and compare baseband chip logs. With SIMtrace2, we can still observe the USIM read order. On a Google Pixel 6 with Android 13, Samsung’s Shannon baseband chip reads files from the USIM as follows: (1) SPN, (2) all PNN entries, and (3) all OPL entries. Here, the order of PNN and OPL is swapped compared to iOS.

Moreover, we set up a wireless testbed with Open5GS [35] and srsRAN [52] running on a MiFCOM lab PC. We use a USRP X310 SDR as radio head and a Google Pixel 6 and a Motorola Edge 30 Pro as UEs (see Figure 4b). When the phones connect to the testbed network, they show the network name *Open5GS*, as well as the USIM SPN name. This is fundamentally different from the iPhone, which only displays one network name at a time. However, if the display name

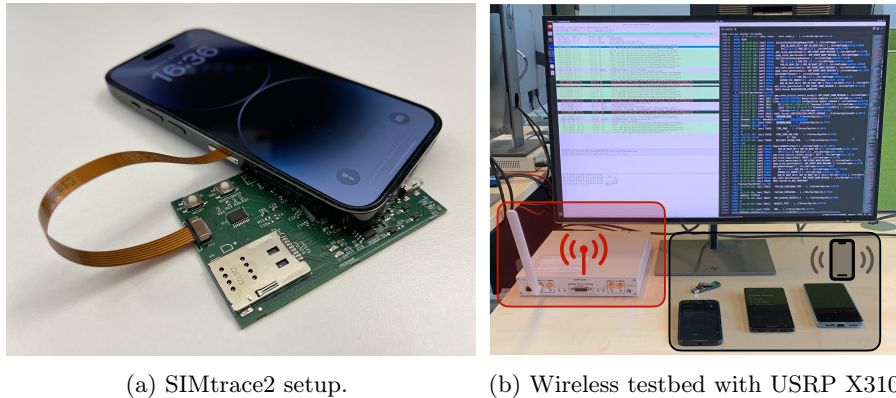


Fig. 4: Physical device and network setups.

sent over NITZ matches the USIM SPN name, this name is displayed only once. Thus, if a network announces a name that complies with the USIM SPN name, the displayed name masks roaming. Though, if the MCC and MNC on the USIM differ from those of the network, an "R" is shown in the status bar to indicate roaming. The network settings menu for the carrier shows the USIM SPN name.

Android on a Google Pixel 6 shows the network name sent over NITZ, the USIM SPN name and a roaming indicator.

Display Names for Roaming Partners Even if iOS and Android prioritized the USIM, roaming partners could still announce a different display name over NITZ. In practice, the PNN and OPL lists on the USIM are not used at all to save roaming partner display names—the USIMs' lists shown in Table 1 only contain the HPLMN name despite previous use in roaming. However, Samsung on Android 13 shows two network names: the one from the USIM for the network operator of the HPLMN and the one sent over NITZ (see Figure 3b). Here, the user clearly sees that they are roaming.

Roaming partners can define arbitrary display names, allowing them to hide roaming. Current Android versions show the network name of the HPLMN and the VPLMN, making the roaming evident.

4.3 Authentication Vector Abuse

Requesting Authentication Vectors A roaming partner can request AVs at any time. It is up to the HPLMN to decide if these requests are legitimate. Requests should be checked carefully and only granted to roaming partners so that they can bill the end user for network traffic and telephony. The 5G AKA

procedure ensures that the UE is present in the roaming partner’s VPLMN to prevent billing fraud. End-users cannot observe which MNOs requested AVs in their name and when, unless resulting costs are eventually listed on their telephone bill.

A state-sponsored attacker’s goal is not billing fraud—they only want to succeed with mutual authentication. Especially when aiming at RCE, maintaining a connection for a few seconds in a post-authentication state can be sufficient. Thus, requesting AVs, even briefly, is sufficient to attack users.

We verify that a roaming partner can indeed request arbitrary AVs from a HPLMN using Open5GS [35]. We leave most of the authentication unmodified: The UE initiates authentication with the MCC and MNC the VPLMN advertises over-the-air and during the communication with the HPLMN. The Access and Mobility Management Function (AMF) in the VPLMN then generates an Serving Network Identifier (SN Id) for the registration request, e.g., `5G:mnc001.mcc001.3gppnetwork.org`. Finally, the SEPP of the VPLMN sends a registration request using the SN Id and the user’s Subscriber Concealed Identifier (SUCI) to the HPLMN. In this final step, we maliciously request an AV for an arbitrary network. To this end, we modify the function `connection_add` in the file `/lib/sbi/client.c` such that the initially requested SN Id is replaced with the attacker’s SN Id. Then, the HPLMN replies with a valid AV for the attacker-chosen SN Id.

When issuing an AV, Open5GS neither filters for roaming agreements nor checks if the originating VPLMN’s network connection matches the requested SN Id.

Commercial MNOs might apply further checks here. Roaming partners, who might not know exact filtering rules, could check for potential weaknesses by sending malicious AV requests. However, roaming requests with mismatching MCC and MNC are specification-compliant. If and how filtering is done is left to MNOs. We assume that filtering rules could be incomplete.

Attacking Users Despite Turned Off Roaming When a UE turns off roaming, it only accepts connections to its HPLMN. However, a malicious VPLMN could announce the same MCC and MNC as a user’s trusted HPLMN. As this happens pre-authentication, the UE has to trust the MCC and MNC. While the HPLMN denies authentication to unknown VPLMNs, it might allow requests to look like they originated originating from its own network. We confirm that an Open5GS HPLMN also answers roaming AV requests for its own MCC and MNC. The problem is that such a connection looks like a legitimate non-roaming connection on the UE. Not even Android devices show a roaming indicator as the MCC and MNC of the network match the MCC and MNC on the USIM.

Users can not prevent roaming requests between networks. Disabling roaming on their UE only limits the MCC and MNC the UE attempts to connect to those of their HPLMN. By using this MCC and MNC, attackers can establish connections looking legitimate and non-roaming.

Unclear Roaming Partnerships In theory, an MNO established in one country would need to have a roaming contract with operators in all other countries worldwide to provide a seamless network experience to their users. Maintaining that many roaming agreements is challenging in practice. The solution to this problem is roaming intermediaries [5,6], also called clearing houses.

In the roaming scenario depicted in Figure 2, the SEPP of the VPLMN connects to the SEPP of the HPLMN. This way, both networks can interact with each other. Roaming intermediaries change this architecture such that there can be up to two roaming intermediaries in between [6, 5.9.3.2]. This simplifies roaming contracts. E.g., an MNO in the US could roam to a roaming intermediary responsible for all of the US, which then roams to a European roaming intermediary, which terminates at a specific European MNO. While roaming intermediaries simplify billing contracts, they pose a risk to the transparency behind roaming agreements. Further, their existence is opaque to users.

Roaming intermediaries complicate trust relationships that could be abused when setting up roaming-based RBSes.

4.4 Network Traffic Rerouting

Network traffic can be routed through the VPLMN or the HPLMN during roaming. These two options are called LBO or HR, respectively. The VPLMN controls the network traffic route solely [4, 4.3.2.2.1], and users are not informed about this routing decision.

The roaming partner can decide to route a user's network traffic through their appliances.

When the VPLMN decides to perform LBO routing, it handles all requests from the UE by itself [4, 4.3.2.2.3.2][8, 5.6.3, 6.3.2]. Only in case of HR does the VPLMN ask the HPLMN to handle requests. The HPLMN can still deny HR and leave the network traffic to the VPLMN. Here, the design of 5G roaming only focuses on the billing aspects of roaming, not the privacy of end-users or the observability of the roaming arrangement.

5 Mitigations

In this section, we propose multiple countermeasures and discuss their feasibility.

5.1 Mitigating the Root Cause

RBSes abusing roaming are especially powerful as they provide access to the decrypted traffic of any connected UE. Ideally, traffic would be encrypted not just when transmitted over the air between UE and gNB but end-to-end between the UE and HPLMN.

A network infrastructure redesign like this would bypass all LI interfaces. Specifically, law enforcement agencies require access to network traffic, phone calls, and SMS of all users located in the country they operate in, regardless of roaming. Thus, we only discuss measures that do not break LI within a country if operated by that country’s legitimate network providers.

5.2 Trust Chain Visibility

Trust decisions in 5G roaming are solely taken by core networks. Roaming is implemented transparently towards the UE. The UE does not see why its HPLMN decided to issue a Home Environment Authentication Vector (HE AV). The identity of the VPLMN and involvement of intermediate clearing houses are only checked by the HPLMN. This allows an RBS to fake various information to stay stealthy while performing attacks.

Ideally, all information used to build trust in 5G roaming would be indicated to the user, including a possibility to inspect the current network’s properties. Such an approach would be similar to TLS, where users are displayed a website’s certification chain and can choose to remove untrusted certificate issuers.

Currently, 5G AKA lacks the possibility of forwarding the chain of trust to the user. Thus, smartphones cannot display any such information, but they even withhold the current network’s MCC and MNC. A mitigation that would effectively prevent roaming-based RBSes would, therefore, require changes in both the specification and the UE’s interface design. While designing such a protocol, including proof of its security properties, is out of the scope of this paper, we consider this the most effective countermeasure.

5.3 Proof of Location

Suppose a gNB is operated outside of its MCC’s country borders. In that case, this indicates a violation of the LI principles, which only allow interception by a country’s law enforcement within that country. Thus, an additional measure would be to add a proof of location to the authentication protocol.

Measuring a gNB’s location can be challenging in practice. As the potentially malicious gNB cannot be trusted, other network components or external entities must validate the gNB’s location. Ideally, this would involve an allowlist of legitimately installed gNBs and separate, trusted measurement nodes.

While this approach would be the closest to meeting the legal requirements, we consider it less practical. Moreover, its realization would involve massive hardware costs.

5.4 Indicators of Roaming Abuse

While the 5G specifications do not provide an effective mitigation so far, there are a few indicators of potential roaming abuse a UE can check for.

Network Traffic Route on UE During roaming, network traffic can be routed through the HPLMN or the VPLMN, as explained in subsection 4.4. The UE can check for rerouting using a traceroute app [25,53]. By evaluating the IP addresses captured in the trace, a UE can determine if its traffic is home-routed or if the VPLMN uses LBO. Traffic rerouting detection could be further automated by collecting typical network constellations for each MNO and regularly comparing this to the actual routes.

RBS Detection An RBS that completes authentication could still show other anomalies. Commercial products promise to detect RBSes based on this [31]. In general, RBS detection relies either on (1) suspicious packets or (2) physical signal properties [44]. With the roaming bypass, an attacker can circumvent detection based on (1). Using modern SDRs, evading detection scores based on (2) becomes affordable. In the past, e.g., bandwidth and frequency stability were limitations. Nowadays, SDRs with 160 MHz bandwidth are available as commercial-of-the-shelf devices [28] and GPS disciplined oscillators (GPSDOs) can compensate for frequency or clock instability effects.

Authentication Timing We assume that state-sponsored attackers with access to roaming infrastructure could also have access to RBSes that are challenging to detect with existing tools. Yet, attackers might be unable to hide all indicators of roaming abuse. One such indicator might be the time from authentication to a successful authenticated connection.

Using analysis tooling for QMI on an iPhone 13 while roaming from Telekom Germany in the UK, we take various captures [19]. Specifically, QMI contains when a base station is first seen. Then, either (1) authentication succeeds, which is visible by the phone getting configurations for data transfer and messaging services, or (2) authentication fails, directly indicated by an authentication failure. We are interested in the timing of the first case, as this could indicate roaming agreements being abused.

However, we could not find any significant time differences in QMI packets. The only exception in our trace is the very first authentication in the roaming scenario. This could either be due to the initial roaming setup or due to cell scanning taking longer to complete after a flight. All following connections to three different roaming providers did not show timing anomalies compared to non-roaming scenarios when using the iPhone within Germany.

5.5 Responsible Disclosure

We discussed our findings with 3GPP in March 2024. They consider LI interfaces mandatory, making finding organizational and technical solutions difficult. Any

solution that prevents unlawful espionage on a technical level must not break LI. In their opinion, a viable solution will require more than displaying end-users the roaming trust chain in a TLS-like manner.

Given the current LI architecture, MNOs must follow organizational requirements, meaning that MNOs must not collaborate for espionage outside of their country. MNOs abusing roaming for espionage could be blocked as a whole. However, we think blocklisting MNOs is no viable solution—the majority of roaming interactions of an attacker-collaborating MNO are likely lawful. While there are commercial spyware vendors who advertise that they offer non-2G interception through roaming, they keep the internals of the solution confidential, especially who their roaming partners are [14], making it difficult to pinpoint collaborating MNOs. Even if one of these RBSes fell into the hands of security researchers, blocking a single MNO would not scale, as this could be replaced by contracting another MNO.

Apple and Google consider mitigations against roaming attacks out of scope. The underlying protocols need to change, which are out of their control.

6 Related Work

Previous research mainly focused on RBS detection rather than RBS prevention. Outside of the core network, RBSes can be detected through mobile apps, often requiring particular rooted Android phone models [22,26,31,49], and standalone SDRs and modems [27,41]. RBSes were often considered not to be able to complete authentication in 3G, and thus, downgrade the connection to 2G [33,36,44]. However, roaming abuse for MitM attacks on 3G and 4G networks has been uncovered recently [14]. Roaming agreements also leave other doors open. Recent reports indicate that roaming agreements are used extensively for user location tracking [39]. Our work shows that possible attacks go beyond this and are still present in 5G.

7 Conclusion

5G roaming security has been designed with the primary goal of preventing billing fraud. By analyzing the 5G specifications, we show that the 5G roaming architecture leaves room for state-sponsored attacks. Here, the attacker’s goal contradicts billing fraud, resulting in multiple unprotected attack surfaces. During roaming, the network details provided by a malicious roaming partner make it difficult for a trusted MNO to decide when to proceed with authentication. On a user’s smartphone, there is no way to verify roaming decisions and the underlying trust assumptions in core networks. We demonstrate that the implementation of Open5GS does not prevent such attacks. Our work aims to raise awareness about these issues to solve them in the next generations of cellular networks.

Acknowledgments. This work has been co-funded by the Federal Ministry of Education and Research of Germany in the project Open6GHub (grant number: 16KISK014).

References

1. 3GPP: Network Domain Security (NDS); IP network layer security. Technical Specification (TS) 33.210, 3GPP (2022), version 17.1.0
2. 3GPP: Network Identity and TimeZone (NITZ). Technical Specification (TS) 22.042, 3GPP (2022), version 17.0.0
3. 3GPP: Characteristics of the Universal Subscriber Identity Module (USIM) application. Technical Specification (TS) 31.102, 3GPP (2023), version 18.0.0
4. 3GPP: Procedures for the 5G System (5GS). Technical Specification (TS) 23.502, 3GPP (2023), version 18.4.0
5. 3GPP: Public Land Mobile Network (PLMN) Interconnection. Technical Specification (TS) 29.573, 3GPP (2023), version 18.5.0
6. 3GPP: Security architecture and procedures for 5G system. Technical Specification (TS) 33.501, 3GPP (2023), version 18.4.0
7. 3GPP: Service principles. Technical Specification (TS) 22.101, 3GPP (2023), version 18.5.0
8. 3GPP: System architecture for the 5G System (5GS). Technical Specification (TS) 23.501, 3GPP (2023), version 18.4.0
9. 3GPP: Lawful Interception (LI) architecture and functions. Technical Specification (TS) 33.127, 3GPP (2024), version 18.7.0
10. 3GPP: Lawful Interception (LI) Implementation Guidance. Technical Specification (TS) 33.929, 3GPP (2024), version 0.0.21
11. 3GPP: Lawful Interception requirements. Technical Specification (TS) 33.126, 3GPP (2024), version 19.0.0
12. 3GPP: Protocol and procedures for Lawful Interception (LI). Technical Specification (TS) 33.128, 3GPP (2024), version 18.7.0
13. Amnesty Tech: NSO Group spyware used against Moroccan journalist days after company pledged to respect human rights (2020), <https://www.amnesty.org/en/latest/news/2020/06/nso-spyware-used-against-moroccan-journalist>
14. Amnesty Tech: Predator Files: Technical deep-dive into Intellexa Alliance's surveillance products (2023), <https://securitylab.amnesty.org/latest/2023/10/technical-deep-dive-into-intellexa-alliance-surveillance-products/>
15. Apple: About Lockdown Mode (2023), <https://support.apple.com/en-us/105120>
16. Apple: Apple device support for private 5G and LTE networks (2023), <https://support.apple.com/guide/deployment/support-for-private-5g-and-lte-networks-depac6747317/web>
17. Apple: iOS 17.3 Firmware for iPhone 14 Pro (2023), https://updates.cdn-apple.com/2024WinterFCS/fullrestores/042-81174/16619A78-E8C1-453B-A996-6826E5A4FCB8/iPhone15,2_17.3_21D50_Restore.ipsw
18. Apple: Bug Reporting Profiles and Logs (2024), <https://developer.apple.com/bug-reporting/profiles-and-logs/>
19. Arnold, L., Hollick, M., Classen, J.: Catch You Cause I Can: Busting Rogue Base Stations using CellGuard and the Apple Cell Location Database. In: Under Submission (2024)
20. Association, G.: VoLTE Implementation Guide (2021), <https://www.gsma.com/get-involved/working-groups/wp-content/uploads/2021/01/VoLTE-Implementation-Guide-Jan-2021.pdf>
21. Beniamini, G.: Over The Air - Vol. 2, Pt. 3: Exploiting The Wi-Fi Stack on Apple Devices (2017), <https://googleprojectzero.blogspot.com/2017/10/over-air-vol-2-pt-3-exploiting-wi-fi.html>

22. CellularPrivacy: Android IMSI-Catcher Detector (2023), <https://github.com/CellularPrivacy/Android-IMSI-Catcher-Detector>
23. Classen, J., Gringoli, F., Hermann, M., Hollick, M.: Attacks on Wireless Coexistence: Exploiting Cross-Technology Performance Features for Inter-Chip Privilege Escalation. In: IEEE Symposium on Security and Privacy. pp. 1229–1245 (2022). <https://doi.org/10.1109/SP46214.2022.9833639>
24. Classen, J., Heinrich, A., Reith, R., Hollick, M.: Evil Never Sleeps: When Wireless Malware Stays On after Turning Off iPhones. In: Proceedings of the 15th ACM Conference on Security and Privacy in Wireless and Mobile Networks. p. 146–156. WiSec '22, ACM, New York, NY, USA (2022). <https://doi.org/10.1145/3507657.3528547>
25. ComcSoft Corporation: iNetTools - Ping, DNS, Port Scan (2024), <https://apps.apple.com/de/app/inettools-ping-dns-port-scan/id561659975>
26. Dabrowski, A., Pianta, N., Klepp, T., Mulazzani, M., Weippl, E.: IMSI-Catch Me If You Can: IMSI-Catcher-Catchers. In: Proceedings of the 30th Annual Computer Security Applications Conference. p. 246–255. ACSAC '14, ACM, New York, NY, USA (2014). <https://doi.org/10.1145/2664243.2664272>
27. Electronic Frontier Foundation: Crocodile Hunter (2022), <https://github.com/efforg/crocodilehunter>
28. Ettus Research: Usrp x310 (2024), <https://www.ettus.com/all-products/X310-KIT/>
29. Google: Android 14 introduces first-of-its-kind cellular connectivity security features (2023), <https://security.googleblog.com/2023/08/android-14-introduces-first-of-its-kind.html>
30. GSM Association: TS.25 Mobile Network Codes and Names Guidelines and Application Form (2018), https://www.gsma.com/newsroom/gsma_resources/ts-25-mobile-network-codes-and-names-guidelines-and-application-form/
31. GSMK: Prodcuts: Network Security (2023), <https://www.gsmk.de/products/network-security/>
32. Huntley, S.: Buying Spying: How the commercial surveillance industry works and what can be done about it (2024), <https://blog.google/threat-analysis-group/commercial-surveillance-vendors-google-tag-report/>
33. Karakoc, B., Fürste, N., Rupprecht, D., Kohls, K.: Never Let Me Down Again: Bidding-Down Attacks and Mitigations in 5G and 4G. In: Proceedings of the 16th ACM Conference on Security and Privacy in Wireless and Mobile Networks. WiSec '23 (2023), <https://doi.org/10.1145/3558482.3581774>
34. Kröll, T., Kleber, S., Kargl, F., Hollick, M., Classen, J.: ARISTOTELES – Dissecting Apple’s Baseband Interface. In: Computer Security – ESORICS 2021. pp. 133–151. Springer International Publishing, Cham (2021)
35. Lee, S.: Open5GS (2023), <https://open5gs.org/open5gs/release/2023/12/04/release-v2.7.0.html>
36. Li, Z., Wang, W., Wilson, C., Chen, J., Qian, C., Jung, T., Zhang, L., Liu, K., Li, X., Liu, Y.: FBS-Radar: Uncovering Fake Base Stations at Scale in the Wild. In: NDSS (2017)
37. Maier, D., Seidel, L., Park, S.: BaseSAFE: Baseband Sanitized Fuzzing through Emulation. In: Proceedings of the 13th ACM Conference on Security and Privacy in Wireless and Mobile Networks. p. 122–132. WiSec '20, ACM, New York, NY, USA (2020). <https://doi.org/10.1145/3395351.3399360>
38. Marczak, B., Scott-Railton, J., Roethlisberger, D., Razzak, B.A., Anstis, S., Deibert, R.: Predator in the Wires (2023), <https://citizenlab.ca/2023/>

- 09/predator-in-the-wires-ahmed-eltantawy-targeted-with-predator-spyware-after-announcing-presidential-ambitions/
39. Miller, G., Parsons, C.: Finding You (2023), <https://citizenlab.ca/2023/10/finding-you-teleco-vulnerabilities-for-location-disclosure/>
 40. Miru, G.: Path of Least Resistance: Cellular Baseband to Application Processor Escalation on Mediatek Devices (2017), https://comsecuris.com/blog/posts/path_of_least_resistance/
 41. Ney, P., Smith, I., Cadamuro, G., Kohno, T.: SeaGlass: Enabling City-Wide IMSI-Catcher Detection. In: Proceedings on Privacy Enhancing Technologies (2017). <https://doi.org/10.1515/popets-2017-0027>
 42. Operation Zero: Prices (2023), <https://opzero.ru/en/prices/>
 43. Osmocom: Simtrace 2 (2024), <https://osmocom.org/projects/simtrace2/wiki>
 44. Park, S.: Why We Cannot Win: On Fake Base Stations and Their Detection Methods (2023), <https://api-depositonce.tu-berlin.de/server/api/core/bitstreams/99520397-8b47-4ea4-acd6-2b17c9a78bd4/content>
 45. Pesonen, L.: GSM Interception (1999), <http://www.tml.tkk.fi/Opinnot/Tik-110.501/1999/papers/gsminterception/netsec.html>
 46. Quintin, C.: Google Releases “Disable 2G” Feature for New Android Smartphones (2022), <https://www.eff.org/de/deeplinks/2022/01/victory-google-releases-disable-2g-feature-new-android-smartphones>
 47. Ravnås, O.A.V.: Frida (2024), <https://frida.re>
 48. Ruge, J., Classen, J., Gringoli, F., Hollick, M.: Frankenstein: Advanced Wireless Fuzzing to Exploit New Bluetooth Escalation Targets. In: 29th USENIX Security Symposium (USENIX Security 20). pp. 19–36. USENIX Association (Aug 2020), <https://www.usenix.org/conference/usenixsecurity20/presentation/ruge>
 49. Security Research Labs: SnoopSnitch (2022), <https://opensource.srlabs.de/projects/snoopsnitch>
 50. Sevens, B., Lecinge, C.: Spyware vendor targets users in Italy and Kazakhstan (2022), <https://blog.google/threat-analysis-group/italian-spyware-vendor-targets-users-in-italy-and-kazakhstan/>
 51. Silvanovich, N.: How To Hack Shannon Baseband (2023), <https://www.youtube.com/watch?v=LJ1NzJLMDUs>
 52. Software Radio Systems: srsRAN Project (2024), <https://www.srsran.com/5g>
 53. StreamSoft: PingTools Network Utilities (2024), <https://play.google.com/store/apps/details?id=ua.com.streamsoft.pingtools>
 54. Zerodium: Zerodium Payouts (2019), <https://zerodium.com/program.html>

Appendix

Authentication in a Roaming Scenario in Detail For successful authentication, the HPLMN must collaborate with the VPLMN, implemented through multiple network functions in each network that interact with each other.

When connecting to a VPLMN, the UE sends a registration request to the AMF of the VPLMN. The AMF requests the Authentication Server Function (AUSF) of the UE’s HPLMN to authenticate the UE [6, 6.1.2]. The AUSF forwards the request to the Unified Data Management Function (UDM) of the HPLMN to get the HE AV for the UE. The HE AV is generated based on the UE’s credentials and a current network challenge [6, 6.1.3.2]. Using the HE AV,

the AUSF constructs the Serving Environment Authentication Vector (SE AV) and sends it to the AMF. Here, the responsibility changes from the HPLMN back to the VPLMN. The AMF emits an authentication request with a challenge to the UE. The UE calculates a response and sends it in an authentication response back to the AMF. The AMF checks if the response matches the expected result and forwards the response to the AUSF to prove that the UE registered in the VPLMN. The AUSF verifies the UE's response and informs the AMF if the authentication was successful. Afterward, the AMF sends a configuration update command, including the full network name to be displayed to the UE.

5G AKA Protocol Authentication follows the 5G AKA protocol [6, 6.1.3.2]. Figure 2 illustrates the authentication flow. Before the actual authentication, the UE sends a registration request to the SEcurity Anchor Function (SEAF), the authentication function that is part of the AMF [6, 5.6]. The request carries a temporary UE identifier, the MCC and MNC of the HPLMN and the VPLMN.

When the HPLMN receives the registration request from the UE, the UDM generates the HE AV consisting of RANDom challenge (RAND), AUthentication Token (AUTN), eXpected RESponse (XRES)* and K_{AUSF} [6, 6.1.3.2]. K_{AUSF} incorporates the serving network name, a sequence number, an anonymity key, a cipher key and an integrity key [6, A.2]. The AUTN is derived from the sequence number and the anonymity key, making it genuine, while XRES* is computed from XRES, RAND, the serving network name, a cipher key, and an integrity key [6, A.4]. The serving network name is used to bind the derived keys to the serving network [6, 6.1.1.4]. Contrary to intuition, the serving network name does not include the network name displayed on the UE. Instead, it consists of the service code *5G* and the SN Id containing MCC and MNC.

The HE AV that authenticates the SN Id is then sent to the AUSF, which calculates Hash eXpected RESponse* (HXRES*) from XRES* [6, A.5] and K_{SEAF} from K_{AUSF} [6, A.6]. The SE AV consisting of RAND, AUTN and HXRES* is then sent to the SEAF in the VPLMN [6, 6.1.3.2]. Next, the SEAF sends an authentication request containing RAND and AUTN to the UE, which calculates the RESponse (RES) and subsequently RES* from RES, RAND, the serving network name, the cipher key, and the integrity key [6, A.4]. Further, the UE calculates K_{AUSF} from the cipher and integrity keys and K_{SEAF} from K_{AUSF} [6, A.2]. The RES* is then sent to the SEAF in an authentication response.

The SEAF derives Hash RESponse* (HRES*) from RES*, and compares HRES* with HXRES* [6, 6.1.3.2]. On match, the VPLMN considers the authentication successful. The SEAF consequently forwards RES* to the AUSF. This confirms that the UE is connected to the VPLMN, which prevents billing fraud. The AUSF stores K_{AUSF} and compares RES* to the XRES* computed before. If both values coincide, the HPLMN considers the authentication successful. The AUSF sends an authentication response to the SEAF, which contains K_{SEAF} serving as an anchor key for the following communication [6, 6.2.1].